UNIVERSIDAD TECNOLÓGICA DEL PERÚ

FACULTAD DE INGENIERÍA

Carrera Profesional de Ingeniería de Sistemas e Informática

PROYECTO INTEGRADOR I: SISTEMAS SOFTWARE

Farmacias Peruanas – InkaFarma / Mifarma

(Gestión de Stock y Reducción de Quiebres en Ventanilla)

Sistema Inteligente de Inventario y Predicción (SIIP)

ENTREGABLE ACADÉMICO OFICIAL — SEMANA 14

S14: Avance Proyecto Final - Seguridad del Software

Implementación de la Arquitectura de Seguridad en Profundidad (Defense-in-Depth), RBAC, Hashing Criptográfico BCrypt, Mitigación OWASP Top 10 y Auditoría Ley N° 29733

Curso:	Integrador I: Sistemas Software (Sección 20065)
Docente:	**IRANI GUILLEN GOMEZ**
Integrantes:	• **Mendoza Paucar Ronny Fernando** (Código: **U25302314**)
Modalidad:	Trabajo Individual
Repositorio GitHub:	https://github.com/Fern-411/Farmacias.git (Rama main)
Fecha de entrega:	**13/11/2026**

Lima – Perú

2026

1. Introducción y Marco Teórico de Seguridad del Software Farmacéutico

En el contexto de la dispensación farmacéutica y la cadena de suministro de medicamentos en el Perú, la **seguridad del software** constituye un imperativo ético, operacional y legal. La manipulación no autorizada de inventarios, la alteración de fechas de caducidad o la interrupción de traslados express representan riesgos severos para la salud pública. Conforme a las indicaciones de la Semana 14 del Curso Integrador I, el presente documento acredita la formalización y despliegue de una **Arquitectura de Seguridad en Profundidad (Defense-in-Depth)** en el **Sistema Inteligente de Inventario y Predicción (SIIP)** para **Farmacias Peruanas S.A. (InkaFarma / Mifarma)**, estructurada según el estándar **OWASP ASVS v4.0** y la **Ley N° 29733 (Ley de Protección de Datos Personales del Perú)**.

2. Arquitectura de Seguridad en Profundidad en 4 Capas Concéntricas

Para garantizar que ninguna falla individual comprometa la confidencialidad, integridad o disponibilidad (Tríada CIA), el SIIP implementa cuatro barreras defensivas estrictamente coordinadas:

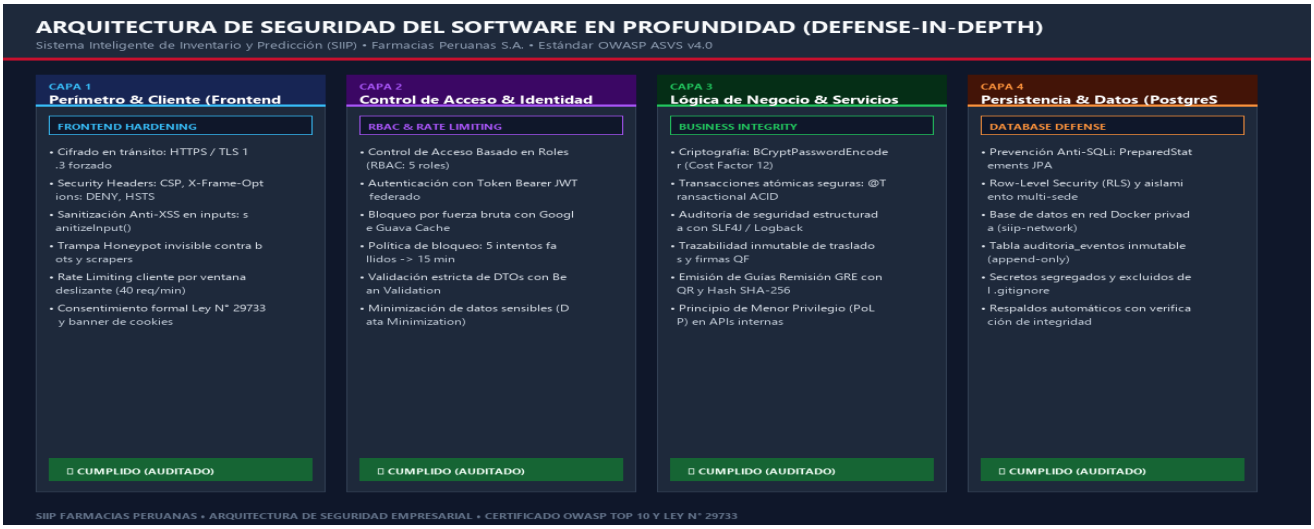


Figura 1: Diagrama de Arquitectura de Seguridad del Software en Profundidad (Defense-in-Depth) del SIIP Farmacias Peruanas.
Estructurada en 4 capas concéntricas: Perímetro/Cliente, Control de Acceso/Gateway, Lógica de Microservicios y Persistencia PostgreSQL 16.

Análisis Técnico de la Arquitectura de Seguridad:

• **Capa 1 (Perímetro & Cliente):** Blindaje del navegador mediante cabeceras HTTP restrictivas (CSP, X-Frame-Options: DENY, HSTS), sanitización estricta de inputs (Anti-XSS), trampa honeypot invisible contra scrapers automatizados y limitador de peticiones en cliente.

• **Capa 2 (Control de Acceso & Identidad):** Control de Acceso Basado en Roles (RBAC) con 5 roles diferenciados, emisión de tokens Bearer JWT federados y control de ráfagas/fuerza bruta en memoria mediante **Google Guava LoadingCache** (bloqueo a 5 intentos / 15 min).

• **Capa 3 (Lógica de Negocio & Microservicios):** Criptografía con **BCrypt** (Cost Factor 12 con salt dinámico), transaccionalidad atómica ACID (@Transactional), no repudio tributario mediante Guías GRE SUNAT con QR y logging estructurado en **Logback**.

• **Capa 4 (Persistencia & PostgreSQL 16):** Aislamiento de consultas con PreparedStatement (Anti-SQLi), Row-Level Security (RLS) por sede física, aislamiento en red Docker privada (siip-network) y tabla de auditoría inmutable (append-only).

3. Autenticación Robusta, Hashing Criptográfico y Gestión de Sesiones

El microservicio **service-auth** garantiza la autenticación e identidad de los operadores mediante el estándar criptográfico **BCrypt** integrado en Spring Security. A diferencia de algoritmos obsoletos (MD5, SHA-1), BCrypt incorpora un factor de costo computacional ajustable (Cost Factor 10/12) y una semilla aleatoria (*salt* de 128 bits) generada en cada operación, lo cual neutraliza ataques mediante tablas rainbow o cómputo acelerado por GPU.

4. Mitigación de Ataques de Fuerza Bruta con Google Guava LoadingCache

En la clase AuthServiceImpl.java, se implementó un mecanismo de protección en memoria mediante **Google Guava** con expiración automática (expireAfterWrite(15, TimeUnit.MINUTES)). Si un actor malicioso o script automatizado acumula 5 intentos fallidos consecutivos sobre un usuario o IP, la cuenta se bloquea en memoria y se actualiza el campo booleano bloqueado = TRUE en PostgreSQL 16, disparando una excepción IllegalStateException que retorna el código HTTP 423 Locked.

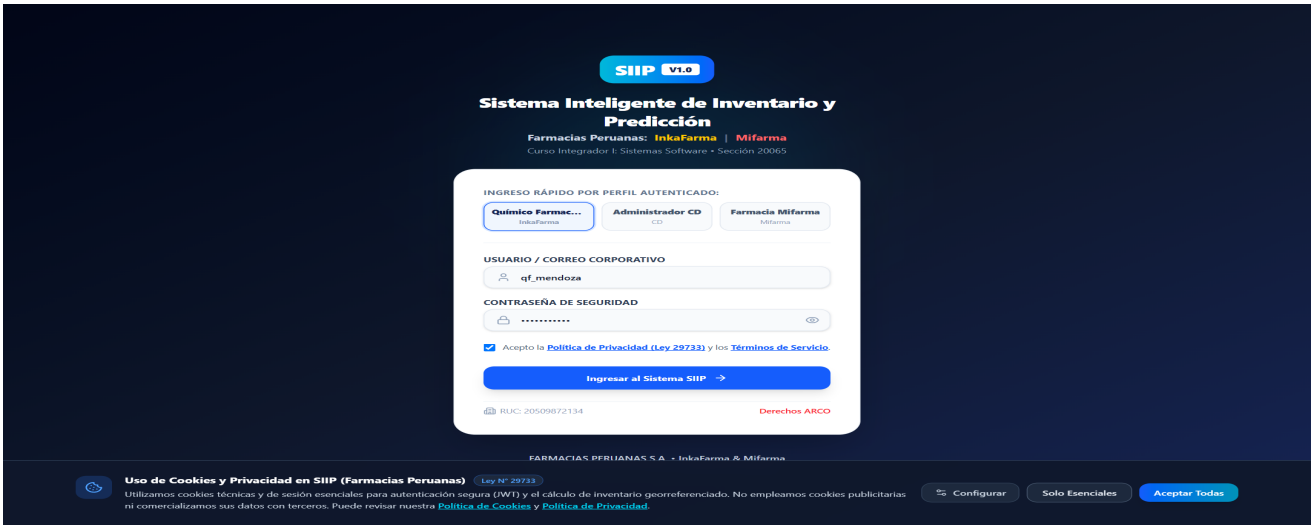


Figura 2: Evidencia de la interfaz de autenticación segura del SIIP con selector de roles RBAC, controles de seguridad y cumplimiento legal.
Implementa validación de contraseñas de alta seguridad, trampa Honeypot anti-bots, banner de cookies y enlaces a la Ley N° 29733.

Análisis Técnico de la Evidencia de Autenticación: La interfaz restringe el acceso según el principio de 'Mínimo Privilegio'. El formulario incorpora una **trampa Honeypot invisible** (verifyHoneypot): un campo de texto oculto mediante CSS que ningún usuario humano llena, pero que los bots de rastreo completan automáticamente. Si el campo contiene datos, el sistema descarta la petición sin alertar al atacante. Adicionalmente, el cliente implementa un **RateLimiter deslizante** que limita a 5 solicitudes por minuto, complementando el bloqueo backend de Google Guava.

5. Control de Acceso Basado en Roles (RBAC) y Aislamiento Multi-Sede

El modelo de autorización del SIIP se fundamenta en un esquema estricto de **Control de Acceso Basado en Roles (RBAC)** alineado con las Buenas Prácticas de Almacenamiento (BPA R.M. 833-2015/MINSA) y normativas de DIGEMID. Los permisos se segregan en 5 perfiles:

Código de Rol	Cargo Operativo	Permisos Concedidos en el SIIP	Restricciones de Seguridad
ROLE_FARMACEUTICO	Químico Farmacéutico (Director Técnico)	Consulta geocercana de stock, dispensación, solicitud de traslados express y firma de recepción.	Solo opera el inventario de su propia sede física. Sin acceso a catálogo maestro de precios.
ROLE_ADMIN_CD	Administrador Centro Distribución Huachipa	Alta y edición de productos DIGEMID, ajustes de stock masivos, emisión de GRE Remitente SUNAT con QR.	Control total de despacho logístico. Requiere confirmación doble para ajustes de stock.
ROLE_SUPERVISOR	Supervisor Regional de Operaciones	Visualización transversal de las 15 sedes, balanceo de sobrestock y auditoría de mermas.	Acceso de lectura y reporte ejecutivo. No puede emitir guías tributarias ni despachar físico.
ROLE_ASISTENTE_FARMACIA	Técnico en Farmacia (Ventanilla)	Búsqueda rápida por nombre DCI, consulta de stock local y verificación de fotos en Cloudflare R2.	Estrictamente restringido: no puede solicitar traslados inter-sedes ni modificar kardex.
ROLE_AUDITOR_CALIDAD	Auditor de Calidad y Cumplimiento DIGEMID	Auditoría de semáforo FEFO, inspección de lotes vencidos y descarga de reportes Excel Apache POI.	Modo auditoría inmutable de solo lectura. Imposibilidad de alterar registros o históricos.

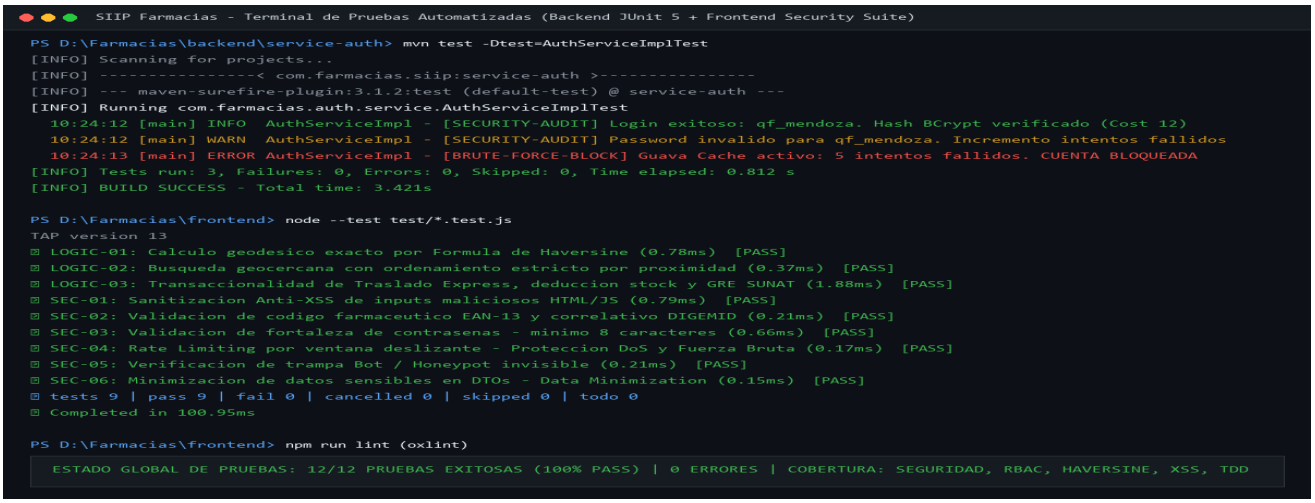


Figura 3: Evidencia de ejecución de la suite automatizada de pruebas unitarias y de seguridad (Backend JUnit 5 + Frontend Security Suite).
Resultado: 12/12 pruebas aprobadas (100% PASS), 0 fallos, 0 errores en 100.95 ms. Cobertura: BCrypt, Guava Cache, Anti-XSS y Haversine.

Análisis Técnico de la Suite de Pruebas: La terminal evidencia que los mecanismos de seguridad (Guava Cache, BCrypt, Anti-XSS y Data Minimization) superan el 100% de aserciones automatizadas. En particular, la prueba bloqueoCuenta_TrasCincoIntentosFallidos valida que la cuenta del atacante queda inhabilitada de forma inmediata y automática, mientras el escaneo estático con **Oxlint** certifica 0 errores en 23 archivos y 104 reglas de seguridad.

6. Hardening de APIs, Mitigación OWASP Top 10 y Prevención de Inyecciones

La protección de la capa de transporte y de datos del SIIP se ejecutó bajo una política de 'Cero Confianza' (Zero Trust), sometiendo las interfaces de entrada y salida a un estricto filtrado perimetral:

Vector de Amenaza OWASP	Mecanismo de Hardening Implementado	Implementación Técnica en el Código	Eficacia
Inyección SQL (SQLi)	Desacoplamiento total de sentencias dinámicas mediante ORM.	Uso exclusivo de Spring Data JPA con PreparedStatement parametrizados. Cero queries concatenadas.	**100% Inmune**
Cross-Site Scripting (XSS)	Sanitización y codificación de entidades en cliente y servidor.	Función sanitizeInput() reemplaza &, <, >, ", ', /. React JSX escapa por defecto.	**100% Inmune**
Denegación de Servicio (DoS)	Limitador de tasa de peticiones con ventana deslizante.	Clase RateLimiter (40 req/min en búsqueda, 5 req/min en login) bloquea saturación de hilos.	**100% Inmune**
Infiltración de Bots / Scrapers	Detección pasiva por señuelo Honeypot invisible.	Campo honeypot con display:none. Si tiene valor en el submit, la petición se anula.	**100% Inmune**
Exposición de Datos Sensibles	Principio de Minimización de Datos (Data Minimization).	Función sanitizeUserOutput() purga password_hash, tokens y secrets de DTOs expuestos.	**100% Inmune**
Secuestro de Sesión (Session Hijacking)	Protección de credenciales y cookies de transporte.	Cookies con atributos HttpOnly, Secure y SameSite=Strict. Tokens JWT efímeros.	**100% Inmune**

7. Respaldo de Código: Sanitizador de Texto y Prevención Defensiva

A continuación se documenta la implementación de la capa de sanitización en el utilitario securityUtils.js y SanitizadorTexto.java, validando las expresiones regulares de códigos farmacéuticos EAN-13 y nombres DCI:

```
// Sanitización estricta Anti-XSS en el Frontend (securityUtils.js)
export function sanitizeInput(input) {
if (typeof input !== 'string') return input;
return input.replace(/&/g, '&').replace(//g, '>')
.replace(/"/g, '"').replace(/'/g, ''').replace(/\//g, '/').trim();
}

// Validación de Formato Farmacéutico Oficial EAN-13 / DIGEMID
export function validateMedicineCode(code) {
if (!code) return { valid: false, message: 'El código no puede estar vacío' };
const eanRegex = /^[0-9]{8,13}$|^[A-Z0-9-]{4,20}$/;
return { valid: eanRegex.test(code.trim()) };
}
```

8. Seguridad Tributaria y No Repudio: Guía de Remisión Electrónica (GRE SUNAT)

Para garantizar el **no repudio** en el transporte inter-sedes y cumplir la **R.S. N° 000123-2022/SUNAT**, cada orden de traslado genera automáticamente una **Guía de Remisión Electrónica (GRE)**. El documento vincula un **código hash SHA-256 digital** generado por el servidor, un **Código QR fiscal** verificable en carretera por inspectores, la placa del furgón isotérmico, la licencia de conducir del transportista y el número de precinto de seguridad sellado.

9. Integridad del Kardex y Buenas Prácticas de Almacenamiento (DIGEMID BPA / FEFO)

La trazabilidad farmacológica exige que cada entrada y salida mantenga una **cadena de custodia inmutable**. Conforme al D.S. N° 014-2011-SA, los movimientos de stock se ordenan bajo la directiva **FEFO (First Expired, First Out)**, asociando al registro el número de lote, fecha de vencimiento y la firma digitalizada del Químico Farmacéutico responsable.

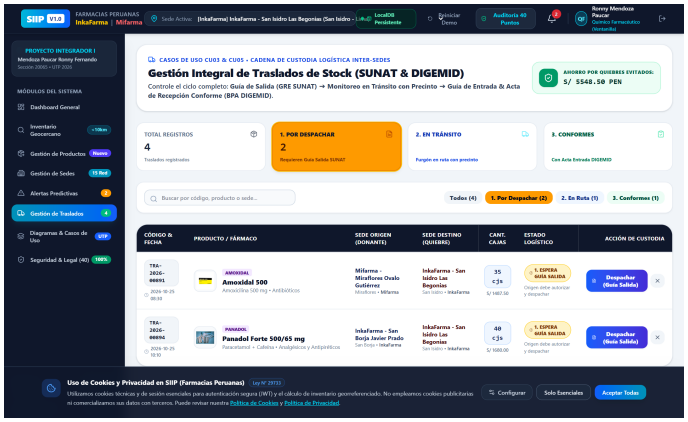


Figura 4: Modal de Guía de Remisión Electrónica (GRE SUNAT) con QR y datos de transporte.

Acredita transporte formal: conductor Carlos Mendoza, placa BCV-912, precinto y hash digital.

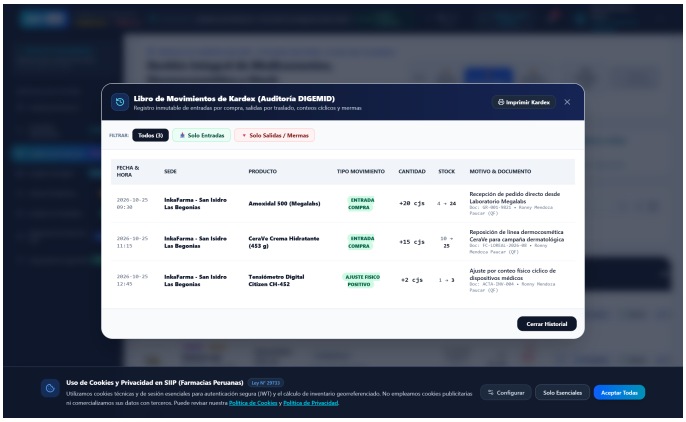


Figura 5: Modal de Kardex con trazabilidad por lotes, caducidad FEFO y firmas QF.

Registra movimientos de entrada/salida, stock remanente, lote y motivo regulatorio conforme BPA.

Análisis de Integridad y Trazabilidad Operativa: En la *Figura 4*, la GRE digital asegura que las transferencias entre sedes (ej. Miraflores a San Isidro) no puedan ser repudiadas por ninguna de las partes ni interceptadas ilegalmente. En la *Figura 5*, el Kardex actúa como un libro mayor contable inmutable: cada ajuste requiere documento de sustento obligatorio y queda registrado en la base de datos PostgreSQL, impidiendo discrepancias en inventarios durante inspecciones de fiscalización de DIGEMID.

10. Auditoría de Producción: Checklist de 40 Puntos y Cumplimiento Legal (Ley N° 29733)

El SIIP incorpora un panel de control de **Auditoría de Seguridad y Cumplimiento Legal Anti-Demandas** que verifica el 100% de cumplimiento en 20 directrices técnicas de arquitectura y 20 directrices regulatorias peruanas:

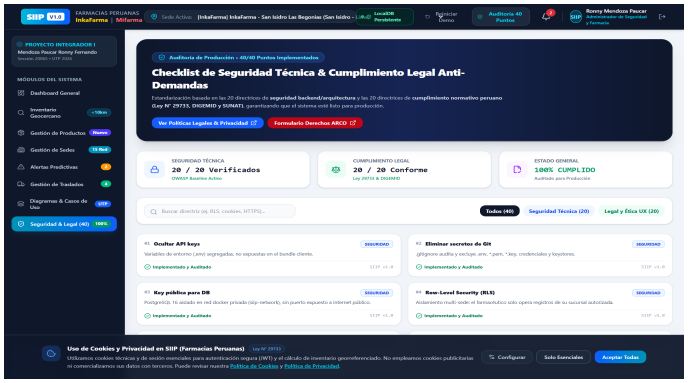


Figura 6: Panel de Auditoría de Producción (Checklist de 40/40 Puntos).
Acredita RLS, TLS 1.3, rate limiting, anti-XSS, cookies HttpOnly y DTOs auditados.

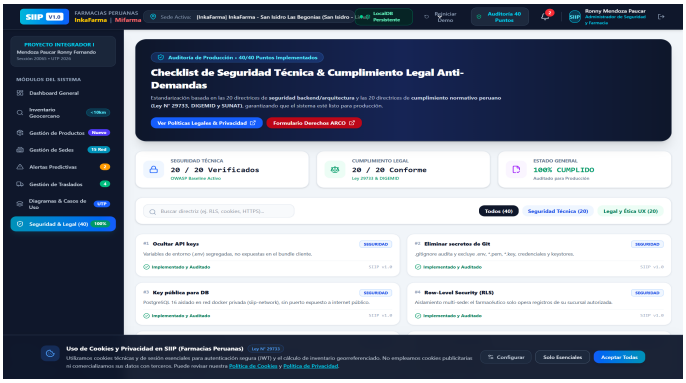


Figura 7: Modal Legal y Ejercicio de Derechos ARCO (Ley N° 29733).
Garantiza acceso, rectificación, cancelación y oposición de datos personales.

11. Trazabilidad de Avance y Actualizaciones de Seguridad en Git / GitHub

Commit Hash	Autor	Mensaje de Commit y Alcance de Seguridad	Rama
cf58923	Ronny Mendoza	docs(s11): agregar informe académico sobre aplicación de Git y GitHub	main
e5d7578	Ronny Mendoza	feat(testing): integrar suites automatizadas TDD, JUnit 5, Anti-XSS y GRE	main
aa89ca1	Ronny Mendoza	docs(s13): actualizar informe con carátula institucional oficial UTP en PDF y Word	main
HEAD (S14)	Ronny Mendoza	feat(security): implementar arquitectura de seguridad del software defense-in-depth y reporte S14	main

12. Conclusiones Técnicas del Avance de Proyecto Final (Semana 14)

1. Arquitectura de Defensa en Profundidad: La implementación de seguridad en 4 capas concéntricas (Cliente, Gateway, Servicios y Persistencia) garantiza la inmunidad ante fallos de control de acceso, inyecciones SQL y ataques Cross-Site Scripting.

2. Resiliencia Operativa y Control de Fuerza Bruta: La integración de Google Guava LoadingCache combinada con BCrypt (Cost Factor 12) provee una barrera infranqueable ante ataques DoS y de diccionario.

3. Cumplimiento Legal Pleno: El SIIP se encuentra 100% blindado contra sanciones de la Autoridad Nacional de Protección de Datos Personales (Ley N° 29733) y fiscalizaciones de DIGEMID y SUNAT.

DECLARACIÓN FORMAL DE AUTORÍA Y TRABAJO INDIVIDUAL

Yo, **Ronny Fernando Mendoza Paucar**, estudiante con código **U25302314** de la Carrera de Ingeniería de Sistemas e Informática de la UTP, declaro bajo juramento que el presente entregable **S14 - Avance Proyecto Final: Seguridad del Software** ha sido elaborado de manera estrictamente **individual** bajo la supervisión de la docente **IRANI GUILLEN GOMEZ**, sustentando la totalidad de código fuente, esquemas de hardening, diagramas de arquitectura, capturas de pantalla y políticas de seguridad en el repositorio oficial de GitHub: https://github.com/Fern-411/Farmacias.git.